

מודול 15 — הנדסה חברתית ופישינג — תרגילים ופתרונות

חומר לימוד

2 יחידות

תוכן העניינים

1.  תרגילים — מודול 15: הנדסה חברתית ופישנינג
2.  פתרונות מלאים — מודול 15: הנדסה חברתית ופישנינג

🎯 תרגילים — מודול 15: הנדסה חברתית ופשינג

⚠️ **אתיקה קריטית!** תרגל רק על עצמך, על מעבדה שלך, או בהרשאה מפורשת בכתב. פשינג של אדם/ארגון ללא רשות = עבירה פלילית ופגיעה באנשים אמיתיים. אל תשלח מיילים מזויפים לאיש ללא אישור. פתרונות ב- `solutions.md`.

🚦 לפני שמתחילים — קרא אותי!

- מה צריך: **Kali** (יש בו SET, theHarvester); לתרגילי הקמפיין — **GoPhish**. לכל הפעולות המעשיות — רק על עצמך / מעבדה / בהרשאה בכתב.
- איך עובדים: קרא קודם את ה- `README.md`. למשימות עם כלי — הפקודה מופיעה; לרעיונות 💡 רמז ו-✅ קריטריון.
- נתקעת? רוב התרגילים כאן הם מחקר וכתובה, לא "פריצה". קרא את הסעיף ב-`README`, ואז הצץ ב- `solutions.md`.
- טיפ: זכור תמיד את הצד האתי — המטרה חינוך והגנה, לא לפגוע.

מקרא רמות: 🟢 קל · 🟡 בינוני · 🟠 מתקדם · 🔴 אתגר

חלק א' — עקרונות (🟢)

- 15.1 — רשום את ששת עקרונות ההשפעה של צ'לדיני, ולכל אחד דוגמה לניצול בפשינג. 💡 רמז: 15.2 `README` (הטבלה). ✅ הצלחה: 6 עקרונות + דוגמה לכל אחד.
- 15.2 — הסבר את ההבדל בין Whaling, Spear Phishing, ו-Phishing. איזה הכי יעיל ולמה? 💡 רמז: 15.3 `README`. ✅ הצלחה: הבחנת נכון; Spear Phishing הכי יעיל (מותאם אישית).
- 15.3 🟢 — נתח מייל פשינג אמיתי מתיקית הספאם שלך. זהה 4 סימני אזהרה. 💡 רמז: 15.5 `README` (סימני הזהוי). רחף מעל הלינקים לבדוק את ה-URL האמיתי. ✅ הצלחה: זיהית 4 סימנים (דומיין שגוי, דחיפות, שגיאות, לינק מטעה...).

חלק ב' — OSINT ותכנון (🟡)

15.4 🟡 — בצע OSINT על עצמך (או חברה בהסכמה).

```
theHarvester -d <domain> -b all
```

👁️ **חפש:** מיילים, שמות ותת-דומיינים שהכלי מצא. + חפש ב-LinkedIn. ✅ הצלחה: הפתעת מכמות המידע הציבורי שקיים.

15.5 🟡 — נסח **מבנה מיילים** של ארגון (first.last@) והסבר איך OSINT עוזר לנחש כתובות. 💡 רמז: 15.4 §README. ✅ הצלחה: הסברת איך מדפוס אחד מרכיבים כתובות לכל העובדים.

15.6 🟡 — כתוב **טקסט** של מייל ספיר-פשינג ("איפוס סיסמת IT"). אילו עקרונות השפעה שילבת? 💡 רמז: 15.5 §, 15.2 §README. שלב סמכות + דחיפות. ✅ הצלחה: מייל משכנע + זיהוי העקרונות שהשתמשת בהם.

חלק ג' — קמפיין מבוקר (🟠)

15.7 🟠 — התקן והרץ **GoPhish**, צור Landing Page-1 Template **במעבדה שלך בלבד**.

```
https://localhost:3333 -ממשק ב # ./gophish
```

💡 רמז: Import Site → Landing Pages → README §15.6 (שבט) → Capture Credentials. ✅ הצלחה: יש לך Landing Page-1 Template מוכנים.

15.8 🟠 — הרץ **קמפיין ניסיוני על עצמך** ובדוק שהמדדים נרשמים. 💡 רמז: 15.6 §README. צור Group עם המייל שלך בלבד, הרץ Campaign, בדוק Results. ✅ הצלחה: ראית מדדי פתיחה/לחיצה נרשמים בדוח.

15.9 🟠 — הסבר כיצד **evilginx** עוקף MFA. 💡 רמז: reverse proxy. 15.7 §README שגונב את ה-session cookie. ✅ הצלחה: הסברת מדוע 2FA לא עוצר פשינג מתקדם.

🔴 אתגר מסכם — "תרגיל מודעות פשינג (מבוקר)"

תכנן קמפיין הדרכת מודעות מלא **על ארגון פיקטיבי** (או מעבדה בהסכמה):

1. **OSINT** — אסוף "מטרות" (רשימה פיקטיבית) ומבנה מיילים.

2. **תסריט (Pretext)** — בחר תרחיש אמין (IT / HR / משלוח).

3. **בנה** ב-GoPhish: Template + Landing Page + Group.

4. **הרץ** על כתובות שלך/הסכמה, ואסוף מדדים.

5. **תעד דוח:** אחוזי פתיחה/לחיצה/מסירה, **בלי שמות**, + המלצות. כתוב את **קטע האתיקה** — איך תציג תוצאות מבלי לבייש עובדים.

💡 רמז: מבנה דוח מלא + דגשי אתיקה ב- `solutions.md` ✓. הצלחה: דוח מודעות עם מדדים (ללא שמות) והמלצות + קטע אתיקה.

📦 דוח מודעות פשינג הוא תוצר מרכזי בבדיקות PNPT. הדגש את הצד המחנך.

✓ רשימת בקרה — לפני מעבר למודול 16

- ☐ אני מכיר את עקרונות ההשפעה ומזהה אותם בהתקפות
- ☐ אני מבחין בין Phishing/Spear/Whaling/Vishing/Pretexting
- ☐ אני מבצע OSINT לאיסוף מטרות (theHarvester, LinkedIn)
- ☐ אני מזהה סימני מייל פשינג
- ☐ אני בונה קמפיין מבוקר ב-GoPhish ומודד תוצאות
- ☐ אני מבין evilginx ועקיפת MFA
- ☐ אני יודע לנהל את הבדיקה **אתית** (Scope, דיווח ללא שיימינג)

פתרונות מלאים: `solutions.md`

✓ פתרונות מלאים — מודול 15: הנדסה חברתית ופשינג

נסה לבד ב- `missions.md` קודם. רק על עצמך / מעבדה / בהרשאה בכתב.

חלק א' — עקרונות

15.1 Reciprocity — “צירפתי לך קופון, אשר את הפרטים”. - **Commitment** — סקר קצר → בהמשך בקשת סיסמה. - **Social Proof** — “כל המחלקה כבר עדכנה את הפרטים”. - **Authority** — “מדבר מנהל ה-IT / הבנק”. - **Liking** — בניית קרבה בציאט לפני הבקשה. - **Scarcity** — “הקישור בתוקף ל-24 שעות בלבד”.

15.2 — **Phishing** = המוני וגנרי; **Spear Phishing** = ממוקד ומותאם אישית; **Whaling** = ספיר-פישנג לבכיר. **Spear Phishing הכי יעיל** — התאמה אישית (שם, תפקיד, פרויקט) מעלה דרמטית את שיעור הלחיצה.

15.3 — סימנים: דומיין שולח שגוי, דחיפות/איום, שגיאות כתיב, לינק שה-URL שלו שונה מהטקסט, בקשת פרטי התחברות.

חלק ב' — OSINT ותכנון

15.4

```
theHarvester -d company.com -b all
# + LinkedIn (עובדים/תפקידים), GitHub, Google Dorking
```

לרוב מפתיע כמה מידע ציבורי קיים: מיילים, מבנה ארגוני, טכנולוגיות.

15.5 — מזהים דפוס מ-OSINT (מייל אחד שדלף) → `firstname.lastname@` → מרכיבים כתובות לכל העובדים שמצאת ב-LinkedIn.

15.6 — דוגמה: “מאת: IT Support. עקב שדרוג אבטחה, אפס את סיסמתך תוך 24 שעות בקישור המצורף אחרת חשבונך יושבת.” — משלב **Scarcity/Urgency** (IT) + **Authority** (24 שעות) + **Fear** (השבתה).

חלק ג' — קמפיין מבוקר

15.7

```
./gophish https://localhost:3333 -משק ב
# Landing Pages → Import Site (שבט) → Capture Credentials
# Email Templates → HTML עם {{.URL}}
```

15.8 — צור Group עם **המייל שלך בלבד**, הרץ Campaign, ובדוק בלשונית Results: Email Opened / Clicked Link / Submitted Data נרשמים.

15.9 — **evilginx** יושב כ-**reverse proxy** בין הקורבן לאתר האמיתי; הקורבן מתחבר (כולל MFA) דרכו, ו-evilginx **גונב את ה-session cookie** אחרי האימות. עם ה-cookie התוקף נכנס בלי לעבור MFA שוב → מוכיח ש-2FA לא עוצר פישנג מתקדם (אך כן מקשה).

>דוח סימולציית פשינג – >ארגון

היקף

.בהרשאת ההנהלה, "IT עובדים, מייל" איפוס סיסמת 120

תוצאות (ללא שמות)

- 68% פתחו את המייל:
- 31% לחצו על הלינק:
- 12% הזינו פרטים:

ניתוח

.שילוב סמכות+דחיפות היה יעיל; מחלקת המכירות הכי חשופה

המלצות

1. הדרכת מודעות + סימולציות רבעוניות
2. בכל המערכות MFA אכיפת
3. סינון אנטי-פשינג + SPF/DKIM/DMARC
4. כפתור "דווח על פשינג" בקליינט המייל

אתיקה

.התוצאות מוצגות כאחוזים בלבד – ללא זיהוי עובדים
.המטרה: חינוך ושיפור, לא ענישה

עברת? יש לך דוח מודעות פשינג אתי ומקצועי. המשך למודול 16.